ECOWAS COMMISSION
COMMISSION DE LA CEDEAO
COMISSÃO DA CEDEAO

cooperation germany – ecowas

EUROPEAN UNION

giz Deutsche Gesellschaft für Internationale Zusammenarbeit (GIZ) GmbH

Global Gateway

SHADOWSERVER

Région de la CEDEAO :

Informations et recommandations en matière de cybersécurité

Le défi :

La cybercriminalité augmente considérablement à travers l'Afrique.

En Afrique de l'Ouest, la cybercriminalité représente plus de 30 % de l'ensemble des crimes signalés.

Dans les États membres de la Communauté économique des États de l'Afrique de l'Ouest (CEDEAO), des cyberattaques coûteuses et dévastatrices ont ciblé des compagnies d'électricité, des banques, des prestataires de services de télécommunications, les sites Internet de services publics et des fabricants, entre autres entités.

30 % DES CRIMES SIGNALÉS en Afrique de l'Ouest relèvent de la cybercriminalité

Facteurs contributifs :

- Une croissance économique et un développement rapides suscitent l'intérêt d'attaquants motivés par l'appât du gain
- L'expansion de l'empreinte numérique augmente le nombre de vecteurs d'attaque disponibles pour violer la sécurité des réseaux
- Les déficiences/« lacunes » en matière de cybersécurité signifient que les capacités se laissent distancer

Principales cybermenaces :

- Logiciels rançonneurs (ransomware)
- Attaques sur des infrastructures critiques
- Attaques par déni de service distribué (DDoS)
- Compromission de messagerie d'entreprise (BEC)
- Arnaques à la fraude en ligne

Les risques de l'inaction :

- Mise en péril des investissements économiques, de la croissance et du développement
- Érosion de la confiance du public
- Impacts sur les services essentiels qui affectent la qualité de vie des citoyens

Lacunes institutionnelles en termes de cybersécurité et recommandations :

Des institutions efficaces

Chaque État membre de la CEDEAO a besoin d'un Centre national de réponse aux incidents de sécurité informatique (CSIRT national) pleinement opérationnel, d'un accès à un Centre de partage et d'analyse de l'information (ISAC) de la CEDEAO et de CSIRT sectoriels en mesure de fournir des services répondant aux besoins spécifiques de chaque secteur.

Accès à des données, outils et services gratuits/abordables

Des fonds limités ainsi que des données sur les menaces, des outils et des services onéreux signifient que les défenseurs de réseau doivent recourir à des options gratuites et/ou abordables. Il s'agit notamment des rapports de remédiation de réseau gratuits de Shadowserver et d'outils tels qu'IntelMQ, Elasticsearch et Kibana, qui sont requis pour assurer une utilisation efficace des fils de données sur les menaces. Certaines options commerciales sont également abordables, dont Arctic Hub, qui est disponible au travers du Programme de développement de CSIRT d'Arctic Security.

Formations et renforcement des capacités

Pour développer des compétences techniques au sein d'un CSIRT ou d'un ISAC, les États membres doivent chercher activement des projets de formation et de renforcement des capacités financés par les ministères gouvernementaux, des entreprises du secteur privé et diverses entités telles que la Banque mondiale, les Nations Unies et l'Union européenne.

Experts techniques internes

Il peut être difficile de recruter et de retenir des employés possédant des compétences techniques supérieures, particulièrement pour les entités gouvernementales qui ne parviennent pas à rivaliser avec les salaires du secteur privé. Les États membres de la CEDEAO doivent travailler avec les universités et le secteur privé pour élaborer des programmes de formation et de mentorat qui peuvent servir de réserve de talents compétents.

Développement de partenariats

Les CSIRT nationaux ne doivent pas travailler en vase clos. Les cadres doivent être conçus de manière à favoriser des partenariats effectifs entre CSIRT nationaux homologues, ainsi qu'avec les fournisseurs d'accès à Internet, les opérateurs d'infrastructures critiques, les entités gouvernementales, les entreprises, les universités et d'autres acteurs similaires. L'établissement de tels partenariats facilitera le partage d'informations, la collaboration et le renforcement des capacités. Des opportunités de partenariats sont disponibles par le biais de FIRST.org et de la communauté en ligne Alliance Mattermost de Shadowserver.



Lacunes institutionnelles en termes de cybersécurité et recommandations :

Évaluations de la maturité

Pour établir un niveau de maturité de référence et assurer un suivi des progrès réalisés en termes de développement, les CSIRT nationaux doivent se soumettre à l'outil d'autoévaluation en ligne (SIM3) du modèle de maturité de la gestion des incidents de sécurité de l'Open CSIRT Foundation et mettre en œuvre les mesures recommandées en matière d'amélioration.

Services d'alerte précoce

Sur la base des rapports de remédiation de réseau gratuits quotidiens de Shadowserver et d'autres fils de données sur les menaces, les CSIRT nationaux doivent proposer des services d'alerte précoce gratuits à tous leurs membres. Ces services permettent aux entreprises abonnées et au reste des membres de recevoir des avis d'alerte automatisés au sujet des appareils et des services qui sont exposés, vulnérables et compromis sur leurs réseaux et qui nécessitent une remédiation en temps utile. Il est recommandé de consulter l'un des nombreux CSIRT nationaux qui fournissent des services d'alerte précoce, notamment le Centre national britannique de la cybersécurité (UK NCSC) et le CSIRT-RD de la République dominicaine.

Lacunes opérationnelles en termes de cybersécurité et recommandations :

Inventaires des actifs

Souvent, les propriétaires de réseau n'ont pas connaissance des actifs qui compromettent leurs réseaux. Des politiques doivent être mises en place pour imposer la conduite d'inventaires réguliers des actifs, particulièrement au sein des gouvernements et des secteurs comprenant des infrastructures critiques, en vue de faciliter une remédiation rapide à mesure que de nouvelles vulnérabilités se présentent.

Actifs exposés

La région contient des actifs qui sont inutilement exposés à l'Internet public, étendant ainsi les surfaces d'attaque et offrant aux attaquants davantage d'opportunités de pirater les réseaux. Des initiatives dédiées avec les CSIRT nationaux, les fournisseurs d'accès à Internet et d'autres propriétaires de réseau dans la région pourraient aboutir à des mesures proactives visant à réduire le nombre d'appareils et de services exposés.

Remédiation des vulnérabilités critiques/de haute gravité

Les réseaux de la région contiennent des vulnérabilités non corrigées que des acteurs malveillants cherchant à s'infiltrer dans ces réseaux pour causer des préjudices peuvent exploiter par le biais de logiciels rançonneurs et d'autres formes d'attaques. Des réglementations doivent être mises en œuvre pour exiger des agences gouvernementales et des opérateurs d'infrastructures critiques qu'ils remédient aux vulnérabilités identifiées comme présentant un « risque critique » dans un délai de 15 jours civils et celles présentant un « risque élevé » dans un délai de 30 jours civils à compter de la date à laquelle elles ont été décelées. Les « vulnérabilités exploitées connues » identifiées comme étant activement exploitées sur la toile doivent être la priorité et faire l'objet d'une remédiation dans un délai de 14 jours civils.

Remédiation des appareils compromis et infectés par des logiciels malveillants

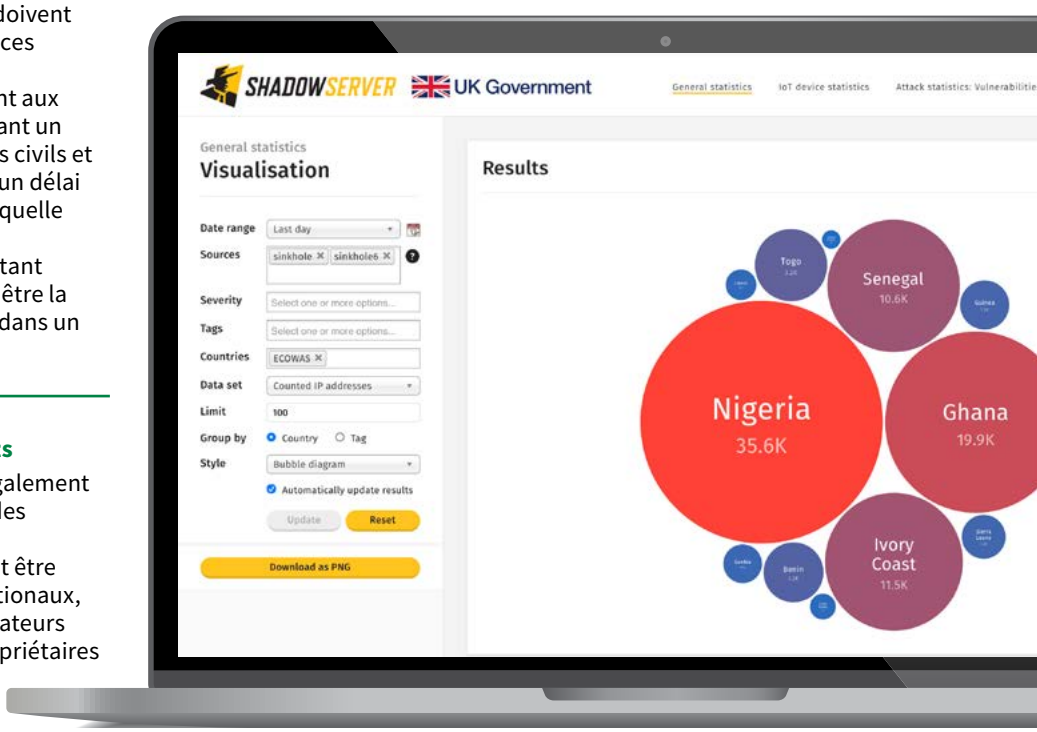
Les réseaux dans la région contiennent également des appareils compromis et infectés par des logiciels malveillants qui nécessitent une remédiation. Des réglementations doivent être mises en œuvre pour exiger des CSIRT nationaux, des agences gouvernementales, des opérateurs d'infrastructures critiques et d'autres propriétaires de réseau majeurs qu'ils remédient dans un délai spécifique aux appareils identifiés comme étant compromis et infectés par des logiciels malveillants, notamment ceux identifiés dans les rapports de remédiation de réseau quotidiens gratuits de Shadowserver qui sont à la disposition de tous les CSIRT nationaux et des propriétaires de réseau abonnés dans l'ensemble des secteurs.

Campagnes d'atténuation/d'élimination des menaces

Concevoir et mettre en œuvre des campagnes nationales d'atténuation et d'élimination des menaces en termes de vulnérabilités critiques et d'appareils compromis sur les réseaux dans l'ensemble de la région. Un exemple récent en est la campagne nationale dirigée par l'Australian Signals Directorate (ASD) en vue d'éliminer des implants dans certains appareils compromis à travers l'Australie.

Tableau de bord public de Shadowserver

Utiliser le Tableau de bord de Shadowserver comme outil pour informer les parties prenantes clés (par ex. les décideurs politiques, les représentants gouvernementaux, les défenseurs de réseau, etc.) au sujet des dernières cybermenaces qui touchent la région.



Regroupement des pays de la région de la CEDEAO dans le Tableau de bord public de Shadowserver